

User Stories -- IBMS (Integrated Business Management Suite)

Field	Detail
Project Name	Integrated Business Management Suite (IBMS) v2.0
Team	Shivansh Srivastava (Product Developer), Prahallad Padhan (Product Owner), Ranveer Rai Khare (Scrum Master)
Sprint	Sprint 1
Date	April 9, 2026
Total Stories	10

US-01: User Registration & Secure Login

As a new employee,
I want to register an account and securely log in to the IBMS platform,
So that I can access business tools and dashboards assigned to my role.

Priority: Critical | **Story Points:** 8

Acceptance Criteria / Checklist

- [x] User can register with username, email, and password
- [x] Password strength is validated in real-time (min 8 chars, mixed case, numeric, special chars)
- [x] Common/weak passwords are rejected (blacklist: **password**, **123456**, **admin**, etc.)
- [x] Passwords are hashed with bcrypt (12 rounds) before storage
- [x] User can log in with username and password
- [x] Successful login returns a JWT access token (30-min TTL) and refresh token (7-day TTL, HTTP-only cookie)
- [x] A CSRF token is returned alongside the access token
- [x] Device fingerprint (user-agent, timezone, screen resolution) is captured and bound to the session
- [x] Failed login attempts are tracked per IP for brute-force protection
- [x] Login error messages do not reveal whether username or password was incorrect
- [x] Frontend displays auth overlay with login and registration forms

- [x] Frontend shows inline password strength meter during registration
-

US-02: Two-Factor Authentication (2FA)

As a security-conscious user,

I want to enable TOTP-based two-factor authentication on my account,

So that my account is protected even if my password is compromised.

Priority: High | **Story Points:** 5

Acceptance Criteria / Checklist

- [x] Authenticated user can call `/api/auth/2fa/setup` to generate a TOTP secret
 - [x] Setup returns a provisioning URI suitable for QR scanning in authenticator apps (Google Authenticator, Authy)
 - [x] User confirms 2FA by submitting a valid 6-digit TOTP code to `/api/auth/2fa/confirm`
 - [x] Once enabled, login requires the TOTP code in addition to username/password
 - [x] TOTP validation allows ± 1 time-step window tolerance (30-second steps)
 - [x] User can disable 2FA via `/api/auth/2fa/disable` when authenticated
 - [x] Frontend login form dynamically shows the 2FA code input field when required
 - [x] Invalid or missing TOTP code during login returns a clear error message
-

US-03: Role-Based Dashboard Access

As an administrator,

I want to assign roles to users so they see only the features and data they are authorized to access,

So that sensitive business information is restricted based on responsibility level.

Priority: Critical | **Story Points:** 8

Acceptance Criteria / Checklist

- [x] Five roles are defined: `super_admin`, `admin`, `manager`, `analyst`, `viewer`
- [x] Role hierarchy supports permission inheritance (e.g., `manager` inherits from `analyst`, which inherits from `viewer`)
- [x] `super_admin` has wildcard (*) access to all endpoints and features
- [x] `viewer` role is restricted to `dashboard.view` and `kpi.view` only
- [x] `analyst` can access reports, AI insights, risk view, compliance view, forecast, and copilot
- [x] `manager` adds export, manage, and approve permissions on top of analyst

- [x] `/api/auth/roles` endpoint lists all roles with their permission sets
 - [x] `/api/auth/me` returns the current user's resolved permissions
 - [x] Audit log endpoint (`/api/audit/log`) requires `audit.view` permission
 - [x] Unauthorized access attempts return `403 Forbidden` with no data leakage
 - [x] Frontend sidebar navigation shows/hides pages based on user permissions
-

US-04: Real-Time KPI Dashboard

As a business manager,

I want to view a live dashboard of key performance indicators that updates automatically,

So that I can monitor business health in real-time without manually refreshing.

Priority: Critical | **Story Points:** 8

Acceptance Criteria / Checklist

- [x] `/api/dashboard` returns current KPI snapshot (revenue, net margin, risk exposure, forecast accuracy, compliance score, alerts, fraud blocked, efficiency, customer satisfaction)
 - [x] `/api/dashboard/history` returns historical KPI data points for trend charts
 - [x] WebSocket endpoint `/ws/kpi` pushes KPI updates to connected clients automatically every 15 seconds
 - [x] WebSocket supports `refresh` message type for on-demand KPI update
 - [x] WebSocket supports `ping/pong` heartbeat for connection health monitoring
 - [x] Frontend displays KPI cards with animated counters and 3D tilt spotlight effects
 - [x] Chart.js is integrated for forecast, analytics, and KPI history trend charts
 - [x] WebSocket auto-reconnects with exponential backoff on disconnection
 - [x] Connection health indicator is visible in the UI (connected/disconnected states)
 - [x] KPI data is cached in Redis (or in-memory fallback) to reduce computation overhead
 - [x] Company-level filtering is supported for multi-entity organizations
-

US-05: AI-Powered Business Insights & Copilot

As a data analyst,

I want to get AI-generated insights and ask natural language questions about business metrics,

So that I can quickly identify trends, anomalies, and actionable opportunities without writing queries.

Priority: High | **Story Points:** 8

Acceptance Criteria / Checklist

- [x] `/api/ai/insights` returns the top 4 AI-generated business insights (anomalies, trends, predictions, recommendations)
 - [x] `/api/ai/anomalies` returns currently active anomalies detected in transaction volume and metrics
 - [x] `/api/copilot/ask` accepts a natural language query and returns context-aware responses spanning KPI, risk, forecast, and compliance data
 - [x] AI assistant can process risk-related queries and return risk metrics from KPI snapshots
 - [x] `recommend_actions()` generates actionable recommendations with confidence scores and recommendation codes
 - [x] Sales forecasting endpoint (`/api/forecast`) returns Prophet Ensemble v2 predictions with confidence interval bands
 - [x] Frontend has a dedicated "AI Insights" page accessible from sidebar navigation
 - [x] Anomaly detection models can be refreshed on demand
 - [x] Invoice anomaly checks can be enqueued asynchronously for background processing
-

US-06: Risk Scoring & Fraud Detection

As a finance controller,

I want to automatically score transactions for risk and detect potential fraud,

So that high-risk or fraudulent transactions are flagged before they cause financial loss.

Priority: Critical | **Story Points:** 8

Acceptance Criteria / Checklist

- [x] `/api/risk/score` calculates a transaction risk score (0-100) with a breakdown of contributing factors
 - [x] `/api/risk/composite` computes a weighted composite risk: amount (50%) + behavior (30%) + compliance (20%)
 - [x] `/api/fraud/detect` runs Isolation Forest algorithm and returns a fraud score (0-1) with a `flag_for_review` boolean
 - [x] High-risk transactions (score > threshold) are flagged for manual review
 - [x] Fraud detection integrates isolation forest scoring as the primary ML model
 - [x] Frontend has a dedicated "Risk & Fraud" page in the sidebar navigation
 - [x] Risk and fraud endpoints return structured JSON responses suitable for downstream workflow automation
 - [x] The decision engine (`/api/decision/evaluate`) routes transactions to approve, review, or reject based on risk levels
-

US-07: Compliance Checking & Audit Trail

As a compliance officer,

I want to automatically validate transactions against control policies and maintain a tamper-evident audit trail,
So that the organization meets regulatory requirements and can demonstrate compliance during audits.

Priority: High | **Story Points:** 5

Acceptance Criteria / Checklist

- [x] `/api/compliance/check` evaluates transactions against a control-set (e.g., high-value transactions > Rs.500K require an approval reference)
- [x] Compliance result returns `passed: true/false` and a list of specific violation codes (e.g., `MISSING_HI GH_VALUE_APPROVAL`)
- [x] All authentication events (login, logout, 2FA setup, token refresh) are recorded in the audit log
- [x] `/api/audit/log` endpoint returns paginated, filterable audit events (requires `audit.view` permission)
- [x] Audit events are base64-encoded for tamper evidence
- [x] Background compliance check job detects stale webhooks and generates AI recommendations for unprocessed items
- [x] Frontend has a dedicated "Compliance" page and "Audit Log" page in sidebar navigation
- [x] Compliance score is displayed as a KPI on the main dashboard (target: 97%+)

US-08: Budget Optimization & Dynamic Pricing

As a department head,

I want to get AI-optimized budget allocations and dynamic pricing recommendations,
So that I can maximize revenue and allocate resources efficiently based on market conditions.

Priority: Medium | **Story Points:** 5

Acceptance Criteria / Checklist

- [x] `/api/budget/optimize` accepts budget line items with amounts and a growth target percentage
- [x] Optimizer returns `current_total` and `optimized_total` (adjusted by growth multiplier)
- [x] `/api/pricing/suggest` accepts demand index, stock level, and competitor pricing data
- [x] Dynamic pricing returns a recommended price using weighted multipliers: demand (+40%), stock (-20%), competitors (+20%)
- [x] Both endpoints return structured JSON suitable for integration with approval workflows
- [x] Frontend has dedicated "Budget Optimizer" and "Dynamic Pricing" pages in sidebar
- [x] Budget approval permission (`budget.approve`) is restricted to `manager` role and above

US-09: Lead Scoring & Inventory Prediction

As a sales manager,

I want to automatically score leads and predict inventory reorder points,

So that my team focuses on high-potential leads and we never run out of critical stock.

Priority: Medium | Story Points: 5

Acceptance Criteria / Checklist

[x] `/api/leads/score` calculates a lead qualification score using weighted model: 55% engagement + 45% fit

[x] Lead score input accepts engagement metrics (email opens, page visits, demo requests) and fit attributes (company size, industry, budget)

[x] Lead scoring returns a numeric score with a qualification tier (hot/warm/cold)

[x] `/api/inventory/predict` calculates reorder points using Prophet-based demand forecasting

[x] Inventory prediction considers lead time, safety stock levels, and demand variability

[x] Frontend has a dedicated "Lead Scoring" page accessible from sidebar

[x] Lead management permission (`leads.manage`) is restricted to `manager` role and above

US-10: System Health Monitoring & Deployment

As a DevOps engineer,

I want to monitor system health in real-time and deploy the platform across Docker, Kubernetes, and AWS,

So that I can ensure high availability and quickly diagnose issues in any environment.

Priority: High | Story Points: 8

Acceptance Criteria / Checklist

[x] `/api/health` returns system status (`healthy/degraded`), Redis connectivity, uptime, total requests, error count, error rate, and WebSocket connection count

[x] `/api/metrics` returns a snapshot of system metrics (request totals, last refresh timestamp)

[x] `/api/system/status` returns detailed status including top endpoints by request count, cache state, and uptime

[x] Every API response includes `X-Trace-Id` (UUID) and `X-Response-Time-Ms` headers for observability

[x] Security headers (CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy) are applied to all responses

- [x] Docker Compose config orchestrates web (FastAPI), nginx (reverse proxy), and Redis with health checks and restart policies
- [x] Kubernetes manifests deploy 3 replicas with readiness probes (15s delay), liveness probes (45s delay), and resource limits (500m-2 CPU, 1-4Gi memory)
- [x] K8s Ingress routes `ibms.example.com` with TLS termination to the service
- [x] Terraform provisions AWS VPC, RDS MariaDB (Multi-AZ, 100GB, 7-day backup), and ElastiCache Redis (encrypted, auto-failover) in private subnets
- [x] Frontend has a dedicated "System Health" page displaying server status and metrics
- [x] Notification system supports paginated queuing via `/api/notifications`

Summary

Story ID	Title	Priority	Points	Status
US-01	User Registration & Secure Login	Critical	8	[x] Done
US-02	Two-Factor Authentication (2FA)	High	5	[x] Done
US-03	Role-Based Dashboard Access	Critical	8	[x] Done
US-04	Real-Time KPI Dashboard	Critical	8	[x] Done
US-05	AI-Powered Business Insights & Copilot	High	8	[x] Done
US-06	Risk Scoring & Fraud Detection	Critical	8	[x] Done
US-07	Compliance Checking & Audit Trail	High	5	[x] Done
US-08	Budget Optimization & Dynamic Pricing	Medium	5	[x] Done
US-09	Lead Scoring & Inventory Prediction	Medium	5	[x] Done
US-10	System Health Monitoring & Deployment	High	8	[x] Done
	Total Story Points		68	